RESUME STANDAR COMMON VULNERABILITY SCORING SYSTEM (CVSS) VERSI 4.0

Mata Kuliah: Praktikum Keamanan Sistem Informasi
Topik Bahasan: Standarisasi Penilaian Keparahan Kerentanan Perangkat Lunak
Penyusun: Tim Analis Keamanan Sistem Informasi
Target Studi Kasus: Aplikasi Web FindServices (Laravel 12 Marketplace)
Referensi Utama: FIRST CVSS-SIG (*Forum of Incident Response and Security Teams*) — https://www.first.org/cvss/

DAFTAR ISI

1. BAB I: PENGERTIAN, TUJUAN, DAN PENGELOLA CVSS
2. 1.1 Latar Belakang dan Pengertian Dasar
3. 1.2 Tujuan dan Filosofi Desain (*Severity vs. Risk*)
4. 1.3 Badan Pengelola dan Sejarah Evolusi Standar
5. BAB II: KELOMPOK METRIK CVSS VERSI 4.0
6. 2.1 Skema Nomenklatur Skoring Baru (CVSS-B, BT, BE, BTE)
7. 2.2 Kelompok Metrik Dasar (*Base Metric Group*)
8. 2.3 Kelompok Metrik Ancaman (*Threat Metric Group*)
9. 2.4 Kelompok Metrik Lingkungan (*Environmental Metric Group*)
10. 2.5 Kelompok Metrik Tambahan (*Supplemental Metric Group*)
11. BAB III: STRUKTUR VECTOR STRING, PERHITUNGAN SKOR, DAN TINGKAT KEPARAHAN
12. 3.1 Format dan Tata Aturan Vector String CVSS v4.0
13. 3.2 Metodologi Perhitungan Skor: Konsep *Macro-Vectors* dan *Equivalence Classes*
14. 3.3 Skala Tingkat Keparahan Kualitatif (*Qualitative Severity Rating Scale*)
15. BAB IV: CONTOH PENILAIAN STUDI KASUS ANCAMAN DARI TUGAS STRIDE-DREAD
16. 4.1 Deskripsi Kerentanan: Broken Object Level Authorization (BOLA/IDOR) pada `BookingController`
17. 4.2 Pemetaan dan Justifikasi Metrik CVSS v4.0
18. 4.3 Formulasi Vector String dan Hasil Skoring Komparatif
19. 4.4 Analisis Perbedaan Hasil Evaluasi CVSS v4.0 vs. DREAD
20. BAB V: ANALISIS KOMPARATIF CVSS DAN DREAD, KELEBIHAN, SERTA KETERBATASAN
21. 5.1 Matriks Perbandingan Komparatif CVSS vs. DREAD
22. 5.2 Sinergi Integrasi CVSS dan DREAD dalam Siklus DevSecOps
23. 5.3 Keunggulan Standar CVSS
24. 5.4 Keterbatasan dan Tantangan Implementasi CVSS
25. BAB VI: KESIMPULAN
26. DAFTAR PUSTAKA

BAB I: PENGERTIAN, TUJUAN, DAN PENGELOLA CVSS

1.1 Latar Belakang dan Pengertian Dasar

Dalam ekosistem keamanan siber modern, ribuan kerentanan perangkat lunak (*software vulnerabilities*) ditemukan setiap tahunnya. Sebelum adanya standarisasi penilaian global, vendor perangkat lunak, peneliti keamanan, dan administrator sistem menilai keparahan suatu kerentanan menggunakan terminologi internal yang bersifat subjektif dan beraneka ragam (misalnya pelabelan "Critical", "Moderate", atau "Urgent" tanpa kriteria yang seragam). Hal ini menimbulkan kebingungan operasional, ketidakkonsistenan prioritas penanganan, serta ketidakmampuan organisasi dalam mengukur urgensi tambalan (*patch*) secara akurat.

Untuk mengatasi fragmentasi tersebut, dibentuklah **Common Vulnerability Scoring System (CVSS)**. CVSS adalah standar industri terbuka (*open industry standard*) yang bebas digunakan untuk menilai, mengukur, dan mengomunikasikan karakteristik serta tingkat keparahan (*severity*) kerentanan keamanan perangkat lunak maupun perangkat keras. CVSS mentransformasikan karakteristik teknis kerentanan ke dalam representasi numerik terstandarisasi berskala 0.0 hingga 10.0, yang dilengkapi dengan representasi teks terstruktur yang disebut *vector string*.

1.2 Tujuan dan Filosofi Desain (*Severity vs. Risk*)

Tujuan fundamental dari CVSS adalah menyediakan bahasa bersama (*common language*) yang netral vendor, konsisten, dan dapat diulang (*repeatable*) dalam mendeskripsikan keparahan kerentanan di seluruh dunia. Standar ini memungkinkan tim keamanan untuk membandingkan dampak relatif dari berbagai kerentanan yang terdaftar pada basis data global, seperti *National Vulnerability Database* (NVD) yang dikelola oleh NIST, basis data CVE (*Common Vulnerabilities and Exposures*), dan penasihat keamanan (*security advisories*) vendor.

Salah satu prinsip filosofis paling krusial yang ditekankan dalam dokumen spesifikasi CVSS versi 4.0 adalah pemisahan tegas antara **Keparahan (Severity)** dan **Risiko (Risk)**: - **CVSS mengukur Keparahan (*Severity*)**: Yaitu karakteristik teknis intrinsik dari suatu kerentanan—seberapa mudah kerentanan tersebut dieksploitasi dan seberapa besar potensi kerusakan komputasi yang dapat ditimbulkannya pada sistem. - **CVSS secara mandiri tidak mengukur Risiko (*Risk*)**: Risiko adalah fungsi dari probabilitas terjadinya ancaman nyata dikalikan dengan dampak bisnis aktual pada organisasi. Menentukan risiko membutuhkan variabel kontekstual tambahan yang berada di luar jangkauan skor dasar CVSS, seperti motivasi aktor ancaman, adanya serangan aktif di alam liar (*in-the-wild exploitation*), kontrol keamanan kompensasi pada jaringan lokal, serta nilai aset bisnis yang rentan.

FIRST menegaskan prinsip: $$\text{Risk} \neq \text{CVSS Base Score}$$ Skor dasar CVSS dirancang sebagai salah satu masukan (*input*) teknis penting menuju kerangka manajemen risiko yang lebih holistik, bukan sebagai penentu risiko akhir.

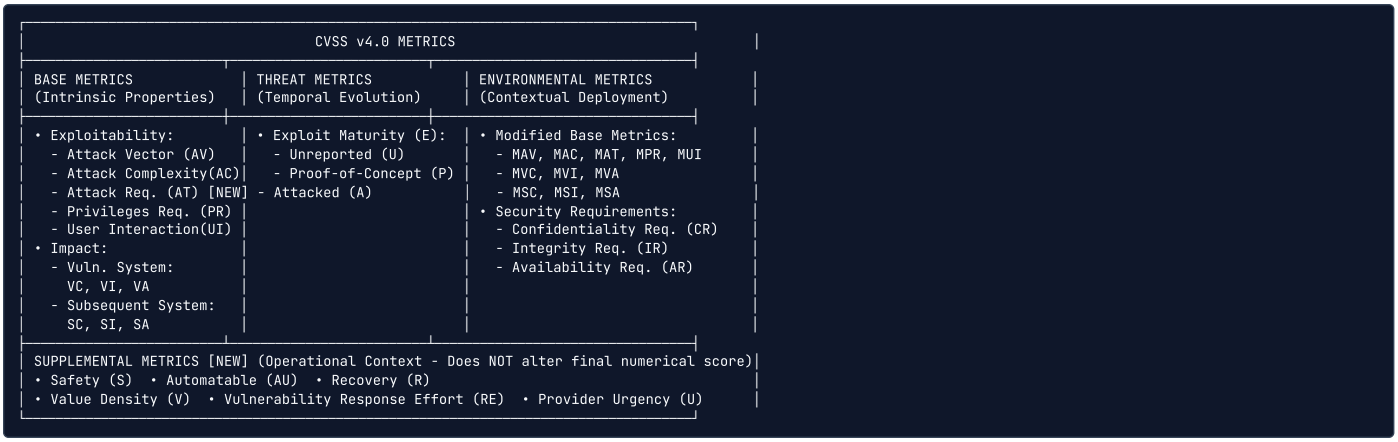
1.3 Badan Pengelola dan Sejarah Evolusi Standar

Pengembangan, standardisasi, dan pemeliharaan CVSS berada di bawah naungan **FIRST** (*Forum of Incident Response and Security Teams*), sebuah organisasi nirlaba internasional terdepan yang memfasilitasi kerja sama tim respons insiden global. Pengelolaan teknis secara spesifik dijalankan oleh kelompok kerja ahli bernama **CVSS Special Interest Group (CVSS-SIG)**. Kelompok ini terdiri dari perwakilan lintas industri terkemuka, lembaga pertahanan, vendor komersial, penyedia teknologi (seperti Cisco, Red Hat, Microsoft, Intel, Oracle), peneliti independen, dan lembaga standardisasi pemerintah seperti NIST (*National Institute of Standards and Technology*).

Evolusi standar CVSS melalui beberapa tonggak sejarah: - **CVSS v1.0 (Februari 2005)**: Didesain awal oleh *National Infrastructure Advisory Council* (NIAC) Amerika Serikat dengan tujuan awal menciptakan mekanisme kuantifikasi kerentanan terpusat. - **CVSS v2.0 (Juni 2007)**: Disempurnakan oleh FIRST untuk mengurangi ketidakkonsistenan penilaian antar analis dan mulai diadopsi luas oleh basis data NVD. - **CVSS v3.0 (Juni 2015) & v3.1 (Juni 2019)**: Memperkenalkan konsep *Scope* (perubahan otorisasi lintas komponen), metrik *User Interaction*, dan penyempurnaan panduan penilaian (*User Guide*). Namun, versi 3.x menghadapi kritik industri terkait fenomena penumpukan skor (*score clustering* di rentang 7.0–8.9) dan kebingungan interpretasi metrik *Scope*. - **CVSS v4.0 (Resmi Dirilis 1 November 2023)**: Merupakan pembaruan generasi terbaru yang merombak arsitektur perhitungan, menghapus metrik *Scope* yang ambigu, memisahkan dampak pada sistem rentan versus sistem turunan, memperkenalkan metrik *Attack Requirements*, menyempurnakan metrik ancaman (*Threat*), serta menambahkan kelompok metrik pelengkap (*Supplemental Metrics*).

BAB II: KELOMPOK METRIK CVSS VERSI 4.0

Struktur CVSS v4.0 disusun secara modular menjadi empat kelompok metrik (*Metric Groups*): **Base**, **Threat**, **Environmental**, dan **Supplemental**.



2.1 Skema Nomenklatur Skoring Baru (CVSS-B, BT, BE, BTE)

Salah satu perbaikan tata kelola terpenting dalam CVSS v4.0 adalah kewajiban mencantumkan nomenklatur skor secara eksplisit untuk mencegah kesalahpahaman umum bahwa skor *Base* adalah skor akhir. Nomenklatur resmi terdiri dari empat kategori: 1. **CVSS-B**: Penilaian yang hanya menggunakan kelompok metrik dasar (*Base Metrics*). 2. **CVSS-BT**: Penilaian yang mengombinasikan kelompok metrik dasar dan ancaman (*Base + Threat Metrics*). 3. **CVSS-BE**: Penilaian yang mengombinasikan kelompok dasar dan lingkungan organisasi (*Base + Environmental Metrics*). 4. **CVSS-BTE**: Penilaian komprehensif terlengkap yang menggabungkan seluruh kelompok metrik dasar, ancaman, dan lingkungan (*Base + Threat + Environmental Metrics*).

2.2 Kelompok Metrik Dasar (*Base Metric Group*)

Kelompok metrik dasar mengukur kualitas intrinsik suatu kerentanan yang konstan lintas waktu dan tidak bergantung pada konfigurasi lingkungan implementasi pengguna akhir. Metrik dasar dibagi menjadi dua sub-kelompok:

A. Metrik Kemudahan Eksploitasi (*Exploitability Metrics*)

1. **Attack Vector (AV)**: Mengukur konteks jaringan atau jalur fisik tempat eksploitasi dapat dilancarkan.
2. *Network (N)*: Celah dapat dieksploitasi dari jarak jauh (*remote*) melalui internet/lapisan perutean L3.
3. *Adjacent (A)*: Membutuhkan akses jaringan lokal yang sama (misal: satu subnet LAN, Bluetooth, Wi-Fi lokal).
4. *Local (L)*: Celah membutuhkan akses konsol lokal, interaksi keyboard langsung, sesi terminal, atau file lokal.
5. *Physical (P)*: Penyerang harus memiliki kontak fisik langsung dengan perangkat keras target.
6. **Attack Complexity (AC)**: Mengukur adanya mekanisme pertahanan keamanan inheren atau teknik komputasi kompleks yang harus dilewati secara sengaja oleh penyerang.
7. *Low (L)*: Tidak ada mekanisme perlindungan bawaan yang menghalangi; eksploitasi bersifat langsung dan dapat diandalkan.
8. *High (H)*: Penyerang harus mengatasi rekayasa pertahanan internal, memecahkan kriptografi, atau menerapkan teknik rekayasa balik khusus.
9. **Attack Requirements (AT)** — *Metrik Baru pada v4.0*: Mengukur ketergantungan eksploitasi terhadap prasyarat kondisi eksternal lingkungan atau *race condition*. Metrik ini memisahkan faktor kondisi lingkungan dari kompleksitas serangan (AC).
10. *None (N)*: Serangan dapat dieksekusi secara deterministik kapan saja tanpa memerlukan kondisi eksternal khusus.
11. *Present (P)*: Serangan bergantung pada kondisi eksternal tertentu (misal: perlunya memicu *race condition*, ketergantungan pada injeksi man-in-the-middle oleh perantara, atau konfigurasi perangkat keras tertentu).
12. **Privileges Required (PR)**: Mengukur tingkat hak otorisasi yang harus dimiliki penyerang sebelum dapat melancarkan serangan.
13. *None (N)*: Tidak terotentikasi / pengguna anonim.
14. *Low (L)*: Membutuhkan akun pengguna dasar (misal: akun pelanggan atau mitra biasa).
15. *High (H)*: Membutuhkan kredensial tingkat administrator, root, atau operator sistem.
16. **User Interaction (UI)**: Mengukur keterlibatan pengguna sah dalam keberhasilan serangan. Pada v4.0, metrik ini diperinci:
17. *None (N)*: Serangan berhasil tanpa keterlibatan pengguna sama sekali.
18. *Passive (P)*: Pengguna sah harus melakukan interaksi sederhana tanpa niat berbahaya (misal: korban hanya membuka tautan situs web atau melihat email).
19. *Active (A)*: Pengguna harus mengambil tindakan manipulatif eksplisit (misal: menonaktifkan peringatan keamanan, menyetujui popup otorisasi, atau memasukkan perintah konsol).

B. Metrik Dampak (*Impact Metrics*)

Pada CVSS v3.x, metrik dampak dikritik karena konsep *Scope (S)* yang menimbulkan ketidakkonsistenan penilaian. CVSS v4.0 merevolusi pendekatan dampak dengan membaginya secara transparan menjadi dua domain CIA (*Confidentiality, Integrity, Availability*):

1. **Dampak pada Sistem Rentan (*Vulnerable System – VC, VI, VA*)**: Mengukur tingkat kerusakan langsung yang dialami oleh modul, komponen, atau aplikasi yang secara fisik memuat kerentanan.
2. *Vulnerability Confidentiality (VC)*: None (N), Low (L), High (H).
3. *Vulnerability Integrity (VI)*: None (N), Low (L), High (H).
4. *Vulnerability Availability (VA)*: None (N), Low (L), High (H).
5. **Dampak pada Sistem Turunan (*Subsequent System – SC, SI, SA*)**: Mengukur tingkat kerusakan lanjutan pada sistem lain di luar batas otorisasi komponen rentan (misalnya: kebocoran basis data pihak ketiga, eskalasi ke sistem operasi *host*, atau disrupsi layanan mikro hulu/hilir).
6. *Subsequent Confidentiality (SC)*: None (N), Low (L), High (H).
7. *Subsequent Integrity (SI)*: None (N), Low (L), High (H).
8. *Subsequent Availability (SA)*: None (N), Low (L), High (H).

2.3 Kelompok Metrik Ancaman (*Threat Metric Group*)

Kelompok metrik ancaman (pada versi terdahulu disebut *Temporal Metrics*) menangkap karakteristik kerentanan yang dinamis dan dapat berubah seiring berjalannya waktu. Metrik utama pada kelompok ini adalah: - **Exploit Maturity (E)**: Mengukur kematangan teknik atau ketersediaan senjata eksploitasi (*exploit toolset*) di domain publik: - *Not Defined (X)*: Nilai default; analis tidak memasukkan metrik ancaman ke dalam perhitungan. - *Unreported (U)*: Belum ada kode exploit publik yang diketahui, atau eksploitasi hanya bersifat teoritis murni. - *Proof-of-Concept (P)*: Kode demonstrasi konsep (*PoC code*) telah dipublikasikan (misal di repositori riset GitHub atau Exploit-DB), namun memerlukan modifikasi untuk serangan riil. - *Attacked (A)*: Solusi eksploitasi siap pakai, kit serangan otomatis (*exploit kit*), atau aktivitas serangan aktif telah terdeteksi secara masif di alam liar (*in the wild*).

2.4 Kelompok Metrik Lingkungan (*Environmental Metric Group*)

Kelompok metrik lingkungan memungkinkan tim keamanan organisasi konsumen untuk menyesuaikan skor dasar CVSS agar mencerminkan konfigurasi infrastruktur dan prioritas bisnis spesifik mereka: 1. **Modified Base Metrics (MAV, MAC, MAT, MPR, MUI, MVC, MVI, MVA, MSC, MSI, MSA)**: Mengizinkan analis mengganti nilai dasar jika organisasi telah menerapkan kontrol mitigasi kompensasi (misal: jika antarmuka yang semula terpapar internet [AV:N] telah dipindahkan ke balik VPN tersegmentasi, maka analis dapat menyetel MAV:A atau MAV:L). 2. **Security Requirements (CR, IR, AR)**: Mengukur tingkat kepentingan relatif dari prinsip Kerahasiaan (*Confidentiality Requirement*), Keutuhan (*Integrity Requirement*), dan Ketersediaan (*Availability Requirement*) aset target bagi kelangsungan operasional organisasi, bernilai *Low (L)*, *Medium (M)*, *High (H)*, atau *Not Defined (X)*.

2.5 Kelompok Metrik Tambahan (*Supplemental Metric Group*)

Merupakan inovasi murni pada CVSS v4.0. Kelompok ini memuat parameter kontekstual yang **tidak memengaruhi skor numerik**, namun memberikan wawasan mendalam bagi analis risiko operasional: - **Safety (S)**: Mengukur potensi bahaya fisik langsung terhadap keselamatan nyawa manusia (*Negligible [N]* atau *Present [P]*). - **Automatable (AU)**: Menunjukkan apakah kerentanan dapat dieksploitasi secara otomatis oleh botnet/worm pada tahapan awal (*No [N]* atau *Yes [Y]*). - **Recovery (R)**: Ketahanan pemulihan sistem pasca-serangan (*Automatic [A]*, *User [U]* yang butuh intervensi manual, atau *Irrecoverable [I]* di mana aset rusak permanen). - **Value Density (V)**: Konsentrasi nilai sumber daya yang dikuasai penyerang (*Diffuse [D]* untuk sistem umum, atau *Concentrated [C]* untuk target bernilai amat tinggi). - **Vulnerability Response Effort (RE)**: Estimasi tingkat kerumitan dan biaya organisasi untuk menerapkan patch atau mitigasi (*Low [L]*, *Medium [M]*, *High [H]*). - **Provider Urgency (U)**: Rekomendasi tingkat urgensi respons dari vendor penyedia perangkat lunak (*Clear*, *Green*, *Amber*, *Red*).

BAB III: STRUKTUR VECTOR STRING, PERHITUNGAN SKOR, DAN TINGKAT KEPARAHAN

3.1 Format dan Tata Aturan Vector String CVSS v4.0

Vector string adalah representasi tekstual padat yang mencatat secara formal setiap nilai metrik yang dipilih dalam sebuah evaluasi kerentanan. Vector string berfungsi sebagai tanda pengenal matematis yang memungkinkan kalkulasi ulang skor secara deterministik oleh sistem lain.

Aturan sintaksis vector string CVSS v4.0: 1. Dimulai dengan penanda versi resmi: `CVSS:4.0/` 2. Diikuti oleh pasangan kunci-nilai (*metric-value pair*) yang dipisahkan oleh karakter garis miring (`/`). 3. Seluruh 11 metrik dasar (*Base Metrics*) wajib diikutsertakan. 4. Metrik dari kelompok *Threat*, *Environmental*, dan *Supplemental* bersifat opsional dan hanya dicantumkan apabila memiliki nilai selain *Not Defined (X)*.

Format Umum:
$$\text{CVSS:4.0/AV:}\dots\text{/AC:}\dots\text{/AT:}\dots\text{/PR:}\dots\text{/UI:}\dots\text{/VC:}\dots\text{/VI:}\dots\text{/VA:}\dots\text{/SC:}\dots\text{/SI:}\dots\text{/SA:}\dots$$

3.2 Metodologi Perhitungan Skor: Konsep *Macro-Vectors* dan *Equivalence Classes*

Berbeda mendasar dari CVSS v3.1 yang mengandalkan formula matematika polinomial kontinu murni (yang rentan terhadap anomali pembulatan desimal dan *score clustering*), CVSS v4.0 mengadopsi algoritma berbasis **Equivalence Classes (EQ)** dan **Macro-Vectors**.

Algoritma CVSS v4.0 membagi dimensi metrik ke dalam 6 kelas ekuivalen: - **EQ1 (Nilai 0–2)**: Dampak maksimum pada sistem rentan ($\text{VC}, \text{VI}, \text{VA}$). - **EQ2 (Nilai 0–2)**: Dampak maksimum pada sistem turunan ($\text{SC}, \text{SI}, \text{SA}$). - **EQ3 (Nilai 0–2)**: Kombinasi vektor eksploitasi dasar (AV, PR). - **EQ4 (Nilai 0–2)**: Kompleksitas eksploitasi dan interaksi pengguna ($\text{AC}, \text{AT}, \text{UI}$). - **EQ5 (Nilai 0–2)**: Kematangan ancaman eksploitasi (E). - **EQ6 (Nilai 0–1)**: Kebutuhan keamanan lingkungan ($\text{CR}, \text{IR}, \text{AR}$).

Kombinasi nilai dari EQ_1 hingga EQ_6 membentuk sebuah *Macro-Vector*. Setiap *Macro-Vector* dipetakan secara terkalibrasi ke dalam tabel pencarian (*lookup table*) yang dirumuskan oleh para pakar keamanan global FIRST. Selanjutnya, nilai skor akhir diinterpolasikan secara diskrit dengan mempertimbangkan tingkat keparahan relatif sub-komponen, menghasilkan skor numerik presisi dari 0.0 hingga 10.0 dengan pembulatan satu digit desimal.

3.3 Skala Tingkat Keparahan Kualitatif (*Qualitative Severity Rating Scale*)

Untuk memfasilitasi komunikasi yang cepat bagi pengambil keputusan non-teknis, skor numerik CVSS v4.0 (rentang 0.0 – 10.0) dipetakan ke dalam skala kualitatif resmi FIRST:

Rentang Skor Numerik	Tingkat Keparahan Kualitatif (*Severity Rating*)	Implikasi dan Karakteristik Operasional
0.0	None	Tidak ditemukan dampak keamanan teknis langsung terhadap sistem.
0.1 – 3.9	Low	Eksploitasi membutuhkan kondisi sulit atau dampak kerusakannya sangat minim. Penanganan dapat dimasukkan ke siklus pemeliharaan berkala.
4.0 – 6.9	Medium	Kerentanan dapat dieksploitasi dengan konsekuensi dampak moderat. Perlu dijadwalkan mitigasi dalam rilis pembaruan reguler.
7.0 – 8.9	High	Kerentanan menimbulkan ancaman serius terhadap integritas, kerahasiaan, atau ketersediaan data penting. Membutuhkan tindakan perbaikan segera.
9.0 – 10.0	Critical	Kerentanan dapat dieksploitasi secara remote tanpa otentikasi dan menimbulkan pengambilalihan kendali sistem penuh. Memerlukan penanganan darurat (*hotfix* segera).

BAB IV: CONTOH PENILAIAN STUDI KASUS ANCAMAN DARI TUGAS STRIDE-DREAD

Untuk mendemonstrasikan penerapan praktis CVSS v4.0, diambil satu ancaman paling kritis dari tugas analisis keamanan website **FindServices** yang telah dimodelkan sebelumnya pada sheet `STRIDE_DREAD_Template` : **Ancaman T-01**.

4.1 Deskripsi Kerentanan Terpilih (Ancaman T-01)

- **ID Ancaman**: T-01 (Referensi CVE-2023-28438 / Taksonomi CWE-639)
- **Nama Celah**: *Broken Object Level Authorization* (BOLA) / *Insecure Direct Object Reference* (IDOR) pada Pembaruan Status Transaksi.
- **Lokasi Kode Sumber**: Repositori FindServices, berkas `app/Http/Controllers/BookingController.php` baris 228–232.
- **Bukti Kerentanan**: Baris validasi otentikasi hak kepemilikan akun sengaja dikomentari: `php // if (auth()->id() !== $booking->provider_id && auth()->id() !== $booking->customer_id) { // abort(403, 'Unauthorized access to booking'); // } $booking->update(['status' => $request->status]);`
- **Mekanisme Serangan**: Penyerang yang memiliki akun pengguna sah (sebagai Customer atau Provider) dapat mengirimkan permintaan HTTP `PATCH /bookings/{order_id}/status` dengan memanipulasi parameter `order_id` milik korban, sehingga penyerang dapat membatalkan atau mengubah status pesanan pihak lain secara sepihak tanpa izin.

4.2 Pemetaan dan Justifikasi Metrik CVSS v4.0

Kelompok Metrik	Parameter Metrik	Nilai Terpilih	Justifikasi Teknis Berdasarkan Analisis Sistem FindServices
Base – Exploitability	Attack Vector (AV)	**Network (N)**	Endpoint API `/bookings/{id}/status` dapat diakses dari jarak jauh melalui jaringan internet publik melalui protokol HTTP.
	Attack Complexity (AC)	**Low (L)**	Tidak ada proteksi built-in atau teknik bypassing kriptografi yang rumit; penyerang cukup memodifikasi nilai integer ID pesanan pada request body/URL.
	Attack Requirements (AT)	**None (N)**	Tidak diperlukan kondisi lingkungan khusus, *race condition*, atau skenario *man-in-the-middle* tertentu agar eksploitasi berhasil.
	Privileges Required (PR)	**Low (L)**	Celah berada di balik middleware `auth:sanctum`; penyerang harus memiliki akun pengguna terdaftar aktif untuk mendapatkan sesi token.
	User Interaction (UI)	**None (N)**	Eksploitasi dijalankan sepihak oleh penyerang; tidak memerlukan interaksi, klik, atau persetujuan dari korban pemilik pesanan.
Base – Vuln. System	Vuln. Confidentiality (VC)	**None (N)**	Endpoint ini murni berfungsi melakukan mutasi status pesanan dan tidak membocorkan data rahasia tambahan dari basis data.
	Vuln. Integrity (VI)	**High (H)**	Integritas data transaksi dilanggar secara masif; penyerang dapat memalsukan status transaksi pesanan bisnis hingga lunas atau batal secara sepihak.
	Vuln. Availability (VA)	**None (N)**	Operasional server Laravel dan ketersediaan aplikasi tidak terganggu atau lumpuh akibat serangan ini.
Base – Subsequent System	Subsequent Confid. (SC)	**None (N)**	Tidak terjadi kebocoran informasi pada sistem di luar batas aplikasi FindServices.
	Subsequent Integrity (SI)	**Low (L)**	Berdampak sekunder pada keutuhan data sistem hilir: riwayat log audit, mutasi pembukuan finansial mitra, dan sistem notifikasi realtime Reverb mencatat status palsu.
	Subsequent Avail. (SA)	**None (N)**	Sistem eksternal (gateway Midtrans, Reverb daemon) tetap beroperasi normal.
Threat (Temporal)	Exploit Maturity (E)	**Proof-of-Concept (P)**	Kode pengujian serangan (*exploit PoC*) telah dibuat dan divalidasi berhasil di lingkungan pengujian laboratorium, namun belum terpantau eksploitasi massal di alam liar.
Environmental	Confid. Requirement (CR)	**High (H)**	Menjaga kerahasiaan data pesanan pelanggan merupakan prioritas tinggi bagi reputasi platform marketplace.
	Integrity Requirement (IR)	**High (H)**	Integritas transaksi finansial dan status pesanan adalah fondasi utama kepercayaan bisnis FindServices.
	Avail. Requirement (AR)	**Low (L)**	Ketersediaan sistem pada fitur ini tidak terdampak langsung.
Supplemental	Automatable (AU)	**Yes (Y)**	Serangan dapat diotomatisasi secara masif dengan skrip bot HTTP sederhana untuk mengubah ribuan status transaksi secara berurutan (*enumeration loop*).
	Recovery (R)	**User (U)**	Pemulihan status pesanan yang telah diubah membutuhkan intervensi administratif manual dari tim operasional FindServices.
	Vulnerability Response Effort (RE)	**Low (L)**	Upaya mitigasi sangat mudah dan murah; pengembang cukup mengaktifkan kembali baris komentar otorisasi hak milik akun atau menerapkan `BookingPolicy`.

4.3 Formulasi Vector String dan Hasil Skoring Komparatif

Berdasarkan metrik yang telah ditentukan, formulasi vector string resmi CVSS v4.0 untuk ancaman T-01 adalah:

$$\text{CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:N/SI:L/SA:N/E:P/CR:H/IR:H/AR:L/AU:Y/R:U/RE:L}$$

Hasil kalkulasi skor resmi berdasarkan algoritma FIRST CVSS v4.0: - **Skor Dasar (CVSS-B)**: **7.1** $\rightarrow$ Tingkat Keparahan: **HIGH** - **Skor Ancaman (CVSS-BT)**: **5.7** $\rightarrow$ Tingkat Keparahan: **MEDIUM** - **Skor Lingkungan Penuh (CVSS-BTE)**: **5.6** $\rightarrow$ Tingkat Keparahan: **MEDIUM**

4.4 Analisis Perbedaan Hasil Evaluasi CVSS v4.0 vs. DREAD

Terdapat perbedaan klasifikasi tingkat risiko yang menarik antara evaluasi DREAD sebelumnya dengan CVSS v4.0 terhadap ancaman T-01 yang sama:

```
┌──────────────────────────────────────────────────────────────────────┐
│                    KOMPARASI PENILAIAN ANCAMAN T-01 BOLA             │
├──────────────────────┬───────────────────────────────────────────────┤
│ METODE EVALUASI      │ HASIL SKOR & TINGKAT KEPARAHAN                │
├──────────────────────┼───────────────────────────────────────────────┤
│ DREAD                │ Total Skor: 40 / 50 ──► CRITICAL              │
│ (Threat Risk Modeling)│ (Damage: 8, Reprod: 9, Exploit: 8, Affected: 8, Discov: 7) │
├──────────────────────┼───────────────────────────────────────────────┤
│ CVSS-B v4.0          │ Base Score: 7.1 / 10.0 ──► HIGH               │
│ (Intrinsic Severity) │ (AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:N/SI:L/SA:N)  │
├──────────────────────┼───────────────────────────────────────────────┤
│ CVSS-BT v4.0         │ Threat-Adjusted Score: 5.7 / 10.0 ──► MEDIUM  │
│ (Temporal Reality)   │ (Faktor E:P menurunkan skor karena exploit belum liar)  │
└──────────────────────┴───────────────────────────────────────────────┘
```

Alasan Utama Perbedaan Skor: 1. **Faktor Pengguna Terdampak (*Affected Users*) dan Penemuan (*Discoverability*)**: Pada metode DREAD, tingginya populasi pengguna yang rentan terkena dampak (skor 8) serta mudahnya celah ditemukan melalui inspeksi endpoint (skor 7) menyumbang poin besar secara linier, sehingga mengangkat ancaman ke level **CRITICAL (Skor 40)**. 2. **Objektivitas Keparahan Teknis pada CVSS Base**: CVSS v4.0 menetapkan bahwa karena celah memerlukan hak akses masuk (*Privileges Required: Low*) serta tidak merusak ketersediaan (*Availability: None*) maupun kerahasiaan data (*Confidentiality: None*), maka tingkat keparahan teknis intrinsiknya berada pada level **HIGH (Skor 7.1)**, bukan *Critical*. Kerusakan *Critical* (≥ 9.0) pada CVSS umumnya mensyaratkan hilangnya ketiga aspek CIA secara penuh atau eksploitasi tanpa hak akses sama sekali (*PR:None*). 3. **Koreksi Realitas Ancaman pada CVSS-BT**: Ketika parameter *Threat* dimasukkan (E:P), skor CVSS-BT terkoreksi turun menjadi **5.7 (Medium)**. Hal ini logis secara operasional: ancaman yang baru berstatus *Proof-of-Concept* di laboratorium belum memiliki urgensi penanganan darurat sebesar ancaman yang sedang dieksploitasi aktif oleh sindikat peretas di dunia nyata (E:A).

BAB V: ANALISIS KOMPARATIF CVSS DAN DREAD, KELEBIHAN, SERTA KETERBATASAN

5.1 Matriks Perbandingan Komparatif CVSS vs. DREAD

Meskipun sama-sama digunakan dalam domain tata kelola keamanan informasi, CVSS dan DREAD memiliki peran, paradigma, dan metodologi yang sangat berbeda:

Parameter Perbandingan	Common Vulnerability Scoring System (CVSS v4.0)	DREAD Threat Risk Ranking Model
Definisi & Fokus Utama	Mengukur **keparahan teknis intrinsik (*severity*)** dari kerentanan perangkat lunak yang telah teridentifikasi secara spesifik.	Mengukur **tingkat risiko komparatif (*risk priority*)** dari skenario ancaman potensial dalam perancangan sistem.
Pengembang / Standar	Dikelola secara global oleh organisasi nirlaba **FIRST**; standar formal de facto internasional.	Awalnya dikembangkan oleh **Microsoft** sebagai bagian dari metodologi *Security Development Lifecycle* (SDL).
Tahapan Siklus SDLC	Ideal pada tahapan akhir SDLC: Pengujian penetrasi (*penetration testing*), audit kode sumber, manajemen kerentanan (*patch management*), dan respons insiden.	Ideal pada tahapan awal SDLC: Analisis kebutuhan, perancangan arsitektur, pemodelan ancaman (*threat modeling* bersama STRIDE).
Perspektif Penilaian	**Objektif dan Kaku**: Didasarkan pada atribut teknis sistem yang dapat diverifikasi secara ilmiah.	**Subjektif dan Kontekstual**: Bergantung pada persepsi tim perancang mengenai dampak dan kemudahan serangan.
Skala Penilaian	Skala desimal kontinu 0.0 – 10.0 dengan 5 tingkatan kualitatif resmi (*None, Low, Medium, High, Critical*).	Skala ordinal 0–10 per dimensi (total 0–50) yang dipetakan ke level risiko (*Low, Medium, High, Critical*).
Dimensi Pengukuran	11 metrik dasar (vektor, kompleksitas, prasyarat, hak akses, interaksi, dampak CIA ganda) + metrik ancaman/lingkungan.	5 dimensi linier: *Damage, Reproducibility, Exploitability, Affected Users, Discoverability.*
Interoperabilitas Industri	Sangat tinggi; terintegrasi langsung dengan ekosistem CVE, NVD NIST, advisory vendor, dan scanner otomatis.	Rendah; umumnya hanya digunakan sebagai dokumen internal tim pengembang atau tugas akademis.
Sensitivitas Waktu	Tinggi; memiliki kelompok metrik *Threat* yang dapat diperbarui saat exploit mulai beredar luas di publik.	Statis; skor umumnya tidak memiliki mekanisme resmi pembaruan temporal otomatis.

5.2 Sinergi Integrasi CVSS dan DREAD dalam Siklus DevSecOps

Daripada mempertentangkan kedua kerangka kerja, organisasi keamanan modern mengintegrasikan DREAD dan CVSS secara komplementer dalam siklus hidup pengembangan perangkat lunak aman (*DevSecOps*): 1. **Fase Desain & Arsitektur (*Design Phase*)**: Tim pengembang menerapkan **STRIDE dan DREAD** saat membuat diagram alur data (DFD). DREAD sangat efektif untuk memprioritaskan skenario ancaman abstrak sebelum sebaris kode pun ditulis. 2. **Fase Pengujian & Audit (*Testing & Verification Phase*)**: Ketika perangkat lunak telah selesai dibangun dan ditemukan kelemahan kode konkret (seperti BOLA pada `BookingController.php`), celah tersebut dinilai menggunakan **CVSS v4.0** untuk menghasilkan skor keparahan teknis resmi dan vector string yang dapat ditindaklanjuti tim *security operations*. 3. **Fase Operasional & Rilis (*Operation & Maintenance*)**: Tim *DevSecOps* menggabungkan skor CVSS dengan data intelijen ancaman real-time (seperti *Exploit Prediction Scoring System* / EPSS) guna menentukan urutan rilis patch prioritas.

5.3 Keunggulan Standar CVSS

1. **Konsistensi dan Standardisasi Universal**: Memungkinkan organisasi di seluruh dunia berkomunikasi menggunakan bahasa metrik yang persis sama tanpa bias vendor.
2. **Granularitas Tinggi pada Versi 4.0**: Pemisahan tegas dampak pada *Vulnerable System* ($VC/VI/VA$) dan *Subsequent System* ($SC/SI/SA$) menyelesaikan kelemahan historis v3.x dalam menilai sistem multi-tier, *cloud infrastructure*, dan API gateway.
3. **Kontekstualisasi Ancaman dan Lingkungan**: Keberadaan metrik *Threat* dan *Environmental* mencegah organisasi membuang sumber daya untuk menambal celah berstatus *Base High* yang sebenarnya berada di jaringan terisolasi dan belum memiliki senjata eksploitasi aktif.
4. **Penyertaan Dimensi Keselamatan Fisik (*Safety*)**: Hadirnya kelompok *Supplemental Metrics* menjadikan CVSS v4.0 relevan untuk sistem *Internet of Things* (IoT), *Operational Technology* (OT), dan *Cyber-Physical Systems* (CPS) seperti perangkat medis dan otomotif.

5.4 Keterbatasan dan Tantangan Implementasi CVSS

1. ***Severity vs. Risk Fallacy* (Kekeliruan Keparahan vs. Risiko)**: Kesalahan paling umum di industri adalah menganggap skor *Base* CVSS sebagai penentu risiko mutlak. Kerentanan dengan skor 9.8 yang berada pada server laboratorium tanpa data sensitif sering kali diperbaiki lebih dulu daripada kerentanan ber-skor 6.5 yang aktif dieksploitasi pada basis data perbankan utama.
2. **Kompleksitas Evaluasi yang Tinggi**: Dengan diperkenalkannya metrik baru pada v4.0 (seperti *Attack Requirements*, *Passive/Active UI*, dan 6 metrik dampak CIA), analis memerlukan pengetahuan arsitektur teknis yang sangat mendalam agar tidak salah memilih nilai metrik.
3. **Keterbatasan Evaluasi Lingkungan di Lapangan**: Sebagian besar basis data publik (seperti NVD) hanya menerbitkan skor *Base* ($CVSS-B$) karena mereka tidak mengetahui konteks lingkungan spesifik pengguna. Sayangnya, banyak organisasi enggan menghitung skor lingkungan ($CVSS-BE/BTE$) secara mandiri karena keterbatasan sumber daya analis.
4. **Kebutuhan Pengayaan Data Eksternal**: Skor CVSS perlu dilengkapi dengan kerangka penilaian probabilitas eksploitasi seperti **EPSS** (*Exploit Prediction Scoring System*) dan katalog **CISA KEV** (*Known Exploited Vulnerabilities*) agar manajemen kerentanan berbasis risiko (*Risk-Based Vulnerability Management*) dapat tercapai secara paripurna.

BAB VI: KESIMPULAN

Berdasarkan kajian komprehensif terhadap standar resmi FIRST CVSS versi 4.0 dan perbandingannya dengan pemodelan ancaman DREAD, dapat ditarik beberapa kesimpulan fundamental:

1. **CVSS v4.0 Merupakan Evolusi Signifikan**: Rilis resmi CVSS v4.0 pada November 2023 sukses memperbaiki berbagai kelemahan historis versi 3.x. Standardisasi baru ini mengeliminasi ambiguitas metrik *Scope* melalui pembagian eksplisit dampak terhadap *Vulnerable System* dan *Subsequent System*, memisahkan kompleksitas eksploitasi dari kondisi lingkungan melalui metrik *Attack Requirements*, serta memperkenalkan nomenklatur transparan ($CVSS-B, BT, BE, BTE$).
2. **Karakteristik Matematis yang Lebih Adil**: Penggunaan pendekatan *Macro-Vectors* dan *Equivalence Classes* pada CVSS v4.0 berhasil mengatasi fenomena *score clustering* pada rentang 7.0–8.9, sehingga distribusi skor menjadi lebih berimbang dan mencerminkan pertimbangan para pakar keamanan siber dunia.
3. **Pembedaan Ranah Kerja CVSS vs. DREAD**: DREAD berfungsi optimal sebagai alat pemeringkat risiko subjektif internal pada tahap awal perencanaan arsitektur (*threat modeling*), sedangkan CVSS merupakan standar evaluasi keparahan teknis objektif untuk kerentanan nyata yang telah teridentifikasi pada implementasi sistem.
4. **Penerapan pada Kasus FindServices (T-01)**: Penilaian kerentanan BOLA pada endpoint `BookingController.php` menghasilkan skor **CVSS-B 7.1 (High)** dengan vector string `CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:N/SI:L/SA:N`. Skor ini memberikan panduan teknis yang presisi bagi pengembang untuk memprioritaskan hotfix validasi otorisasi sebelum meluncurkan aplikasi ke lingkungan produksi.

DAFTAR PUSTAKA

1. **FIRST (Forum of Incident Response and Security Teams)**. (2023). *Common Vulnerability Scoring System v4.0: Specification Document*. Diakses dari https://www.first.org/cvss/v4-0/specification-document
2. **FIRST (Forum of Incident Response and Security Teams)**. (2023). *Common Vulnerability Scoring System v4.0: User Guide*. Diakses dari https://www.first.org/cvss/v4-0/user-guide
3. **FIRST (Forum of Incident Response and Security Teams)**. (2023). *CVSS v4.0 Scoring Calculator and Implementation Reference*. Diakses dari https://www.first.org/cvss/calculator/4.0
4. **NIST (National Institute of Standards and Technology)**. (2023). *National Vulnerability Database (NVD) CVSS Guidelines*. U.S. Department of Commerce. Diakses dari https://nvd.nist.gov/vuln-metrics/cvss
5. **Mell, P., Scarfone, K., & Romanosky, S.** (2007). *A Complete Guide to the Common Vulnerability Scoring System Version 2.0*. Published by FIRST.
6. **OWASP Foundation**. (2023). *OWASP Top 10 API Security Risks: API1:2023 Broken Object Level Authorization (BOLA)*. Diakses dari https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/
7. **Shostack, A.** (2014). *Threat Modeling: Designing for Security*. Indianapolis: John Wiley & Sons, Inc. ISBN: 978-1-118-80999-0.
8. **ISO/IEC**. (2018). *Information technology — Security techniques — Vulnerability disclosure* (ISO/IEC Standard No. 29147:2018). International Organization for Standardization.
9. **CISA (Cybersecurity and Infrastructure Security Agency)**. (2022). *Reducing the Significant Risk of Known Exploited Vulnerabilities*. Binding Operational Directive 22-01. Washington, D.C.: U.S. Department of Homeland Security.
10. **Jacobs, J., Romanosky, S., Edwards, B., & Roytman, M.** (2021). *Exploit Prediction Scoring System (EPSS)*. Digital Threats: Research and Practice, 2(3), 1-17. https://doi.org/10.1145/3436242